

Stack 08 consolidated audit — bounded review receipt

Identity and complete scope

Reviewer: Codex, sole audit agent, 2026-09-27 UTC. Aggregate firmware PR #872, branch audit/715-stack08-on-7b-20260927, base consolidated 7b #871 at 2483977523d9b6beab52a69429ace9aeefd00f76. Integrated code snapshot 551002a2048b7263749fde4b50d01204c1e52bd5; the containing report commit and final CI/review identities are recorded in the live PR receipt. Python #120 stays d9a02d981ee43fe3e80b28ba02466670e6e8409d, clean review 5329239805, CircleCI 548. Other dependency pins are unchanged. This report covers the complete aggregate diff; the inherited A/B reports cover the two code-bearing adjacent review diffs.

The aggregate's file contents exactly match the tip of replacement stack B before adding this aggregate-only source/PDF. No force-push or product merge is performed. Child reviews provide mapped code coverage; #872's earlier finding-bearing verdicts remain historical and are not called clean.

One authorized breakdown and file/finding ownership

The owner authorized three initial requests total, one breakdown, and three requests per resulting unit, followed by a night stop if the audit is not achieved. The conservative recorded limit is two resulting units and nine requests maximum. Initial requests: Python #120 clean; firmware #872 review 5329251034 found one authority issue; review 5329364719 found six further issues. The single breakdown is used; no recursive split remains. At this source freeze A has used two of three requests and B has used zero. Actual counts and outcomes belong in audit-claims/715-08/review-budget-20260927.json in the main worktree and the final live receipt.

Unit	Exact head and base	Owned code and findings
A #873	1172cd309a280845c8d14c372ee45ec7d343e207 on accepted 7b 2483977523d9b6beab52a69429ace9aeefd00f76	Report generator/tests, CI report-test/history/companion metadata, Python pin and duplicate nanopb removal. Findings 4114517037, 4114517067, 4114517093: platform authority, empty ledger and exact product skip reasons. Source/PDF and all 23 historical paths are in the inherited A audit/reconciliation.
B #874	0e1ccc59375a02a95a9c8d3ebd2cd66df7b06fe2 on A 1172cd309a280845c8d14c372ee45ec7d343e207	Preflight, shared cppcheck invocation/version/tests and CI static-analysis steps. Findings 4114517060, 4114517076, 4114517108: remove extraction, verify pinned analyzer and execute report tests once.

The workflow file is owned by both adjacent units in disjoint hunks: A adds report gate/history and companion binding; B replaces static-analysis installation/invoke and adds its focused tests. No production firmware, Python production library, native test or ABI behavior changes. The accepted 7b implementation already supplies the scoped 7.15 display and one-level inner-call behavior. Python adds EX40-EX44 and report requirements; all 39 predecessor runtime method ASTs are unchanged.

Findings, verification and limitations

A selects waiver authority from GitHub's platform base event, validates a full nonzero SHA, and constrains the candidate ledger to that base. Independent fixtures bind a known base distinct from the candidate head and environment pin. Local rehearsal uses the merge base with accepted remote 7b. A round 1 review 5329498209 found two unsafe non-PR fallback choices and a stale reconciliation snapshot. Push/manual reports now require the independently configured repository Actions variable KK_ACCEPTED_WAIVER_SHA or fail closed; no setting was changed. PR authority ignores that override. Tests cover both event modes, missing/malformed authority and PR isolation. The reconciliation JSON and A source report now bind the same repaired code snapshot. A round 2 review 5329587276 also caught a stale JSON test-count field; it now agrees with all 18 passing methods, and authority/skip-reason descriptions are synchronized. Its Solana high finding is technically declined: bounds 8/32/64 remain at lines 16-18. A parsed comparison preserves all 29 effective Solana and 56 Osmosis options against accepted 7b; only identical duplicate copies were removed. Exact counts are retained in JSON and local evidence. A comment marks the retained bounds at the former duplicate location. A has one final request remaining; another finding-bearing result triggers the owner-directed night stop, with no additional split. A unique empty ledger is valid; absent/duplicate ledgers fail. Every dedicated full/BTC contract needs the expected status and exact product-specific skip reason. Eighteen gate tests pass,

including corruption of every expected skip; actual four full/BTC contract artifacts pass. Malicious replacement of the whole checker/workflow remains a code-review boundary.

B shares one explicit argv script between CI and local Docker. Both use Ubuntu cppcheck package 2.13.0-2ubuntu3, verify dpkg and executable version at every invocation, and propagate process failures. Five analyzer tests cover literal argv, stale package, shadowed executable, analyzer failure and invalid invocation. Five additional preflight boundary tests pass (28 including the 18 report-gate and five analyzer tests). Preflight executes the report suite once. The original command-corruption allegation was not reproduced in observed argv; extraction was nevertheless eliminated. Package/version and arguments are matched; operating-system images across architectures are not claimed byte-identical.

Local qualification inherited from unchanged runtime/Python: 65 wire/runtime tests, 39 compiler/catalog/protocol/report tests, 657 native firmware tests, 11 inspected EX42 frames; negative controls reject disabled attacks/chunk bounds and corrupted evidence. Previous replacement preflights passed; all three preflights are repeated after this authority repair and refreshed report freezes. The aggregate preflight is rerun after this final receipt edit before push. Previous aggregate CI 36302640527 passed 1,497 tests with 89 expected skips and zero failure/error. Final aggregate and child CI must bind exact firmware/Python SHAs, both PR URLs, run URL and PDF digest; both ARM variants, native/emulator/integration and release-evidence gates must pass before acceptance.

Current 7.15 owner scope is preserved: optional fields remain visible; unsupported hiding conditions, nested iteration/slices, extra formatter kinds, deeper recursion and typed embedded calls are deferred/refused. Missing or unsupported inner definitions retain explicit blind fallback in AdvancedMode. DELEGATECALL execution-context policy is reserved for 7.16. Hardware validation, assembled release acceptance, product merges and publication remain separate gates. No final clean review or audit completion is claimed at this source freeze; the live receipt must record the delivered exact-head outcomes and remaining budget honestly.

B round 1 findings and verification

Review 5331723008 found two inline issues plus concrete body-only suggestions. The basename search could accept an unrelated file or a comment; preflight now configures the actual test CMake tree with full features and compares tracked test paths against compile_commands.json. Linking is omitted and firmware is not compiled by this source-membership check; real set/list/lf/add_subdirectory semantics remain. Repository-root source paths are exposed through temporary directory aliases. Missing CMake or configuration errors fail closed. This checks membership in the configured full-feature test graph, not runtime test success; native CI remains required.

GNU timeout is replaced by Python subprocess.run(timeout=20), which works on macOS and reports missing, failed or timed-out Docker probes. Whitespace checks use the merge base with the upstream plus the working tree, covering committed changes about to be pushed; PREFLIGHT_BASE explicitly selects the adjacent review base or is required for a first push without an upstream. CI creates the analyzer report before invocation so early package/executable failure still leaves an uploadable report. The analyzer cache is ignored locally. The argv regression asserts every flag, include, define, template, output path and source directory, allowing only the host CPU count to vary.

Five new boundary tests exercise a same-basename collision, comment and unused-list rejection, a repository-root CMake source, committed/worktree whitespace, absent upstream, and Docker timeout/failure behavior. All 28 combined preflight/analyzer/report tests pass, and the structural check passes on the real repository. Initial harness validation caught a CMAKE_SOURCE_DIR relocation problem; temporary directory aliases fixed it and a real-CMake fixture now covers that case. No production firmware, runtime suite, Python pin or A code changed. Final preflight must run after this source/PDF freeze, followed by new exact-head CI/report verification and B request 2/3. Earlier successful runs describe earlier B/aggregate heads.

Complete adjacent aggregate inventory

Added	Deleted	Path
16	26	.github/workflows/ci.yml
3	0	.gitignore
1	1	deps/python-keepkey
110	0	docs/release/audit-units/715-08-audit-20260927.md
-	-	docs/release/audit-units/715-08-audit-20260927.pdf
64	0	docs/release/audit-units/715-08-consolidated-audit-20260927.md
-	-	docs/release/audit-units/715-08-consolidated-audit-20260927.pdf
-	-	docs/release/audit-units/715-08-local-evidence-20260927.tgz
175	0	docs/release/audit-units/715-08-reconciliation-20260927.json
58	0	docs/release/audit-units/715-08B-audit-20260927.md
-	-	docs/release/audit-units/715-08B-audit-20260927.pdf
0	1	include/keepkey/transport/messages-osmosis.options
2	3	include/keepkey/transport/messages-solana.options
1	0	scripts/cppcheck-version
32	0	scripts/cppcheck.sh
96	7	scripts/generate-test-report.py
103	0	scripts/preflight.sh

79	0	scripts/preflight_checks.py
248	0	scripts/test_generate_test_report.py
76	0	scripts/test_preflight_checks.py
91	0	scripts/test_preflight_cppcheck.py